FABRICATING KILL CHAINS

A Safe Approach to OT Purple Teams

Connor Jackson

BSides ICS 2026 • Miami

```
~> whoami
```

Connor Jackson

Senior Consultant @ Security Risk Advisors

Purple Teams

Collaborative attack & defense exercises in IT, Cloud, and OT environments

Penetration Testing

Network, application, and OT assessments

Hardware / Physical

Physical security and hardware hacking

BARRIERS TO OT SECURITY TESTING

Pain-points with traditional penetration testing in OT environments

Risk of Impact / Downtime

Fear of taking down production lines creates hesitation about what attacks a red team can run

Scoping & Scope Creep

Networks excluded due to risk, 3rd-party restrictions, discovered assets not in scope causing delays

Timeboxing Issues

A week-long test is rarely exhaustive for OT environments

No Defense Evaluation

Pentests produce vulnerability lists but don't test if your security tools and team can respond to a real attack

Purple Teams

Purple teams address many of those paint-points

RED TEAM

Performs controlled attacks in an open-book format, demonstrating tools & prerequisites for each technique

BLU TEAM

Analyzes security tool responses — was the attack blocked, did it generate an actionable alert, or are there visibility gaps?

Controlled Risk

High visibility — asset owners see every attack in real-time

Pre-defined Scope

Targets and techniques chosen ahead of time — no surprises

Assumed Compromise

Give attackers access to test specific scenarios

Evaluate Response

Test tool effectiveness and human incident response flows

Building Your Kill Chain

Four steps for designing and running your first OT purple team

01

Identify Assets

Select targets based on risk tolerance and goals

02

Identify Techniques

Map MITRE ATT&CK TTPs from threat intel

03

Execute

Perform the techniques in an open-book format

04

Analyze Results

Identify gaps, prioritize remediations, retest

01 Identifying Assets

What devices should we test?

EXAMPLE SCENARIOS

- Evaluate convergence points found in a recent pentest
- Test the endpoint controls of your jump server
- Verify a new passive OT monitoring tool (Nozomi, Defender for IoT, Dragos, etc.)

EXAMPLE DEVICES

- Engineering Laptop
- File Servers
- Jumper Servers
- Windows-Based HMI's
- Zebra Printers

TIPS FOR SUCCESS

- **IT assets:** tend to be forgiving. Use fresh workstations & dedicated accounts
- **DMZ assets:** are mostly safe. Consider testing during off-hours as a precaution
- **OT assets:** don't need production! Use test beds, decommissioned devices, or more robust targets (ex: printers)

02 Identifying Techniques

What attacks should we perform?

Previous Reports

Pentest reports, vulnerability reports, table-top exercises

Public Threat Intel

Vendor threat reports, CISA advisories

MITRE ATT&CK

Enterprise + ICS matrices for systematic coverage

02 Identifying Techniques

Distilling threat intelligence

THREAT REPORT

CISA Advisory

"Threat group X targets manufacturing sector via spearphishing, moves laterally to OT DMZ, and issues stop commands on PLCs"

MITRE Tags:

T1566, T1021, T1570, T0886, T0855

EXTRACT TTPs

- **T1566** Phishing
- **T1021** Remote Services
- **T1570** Tool Transfer
- **T0886** Remote Svcs (ICS)
- **T0855** Unauth. Cmd Msg

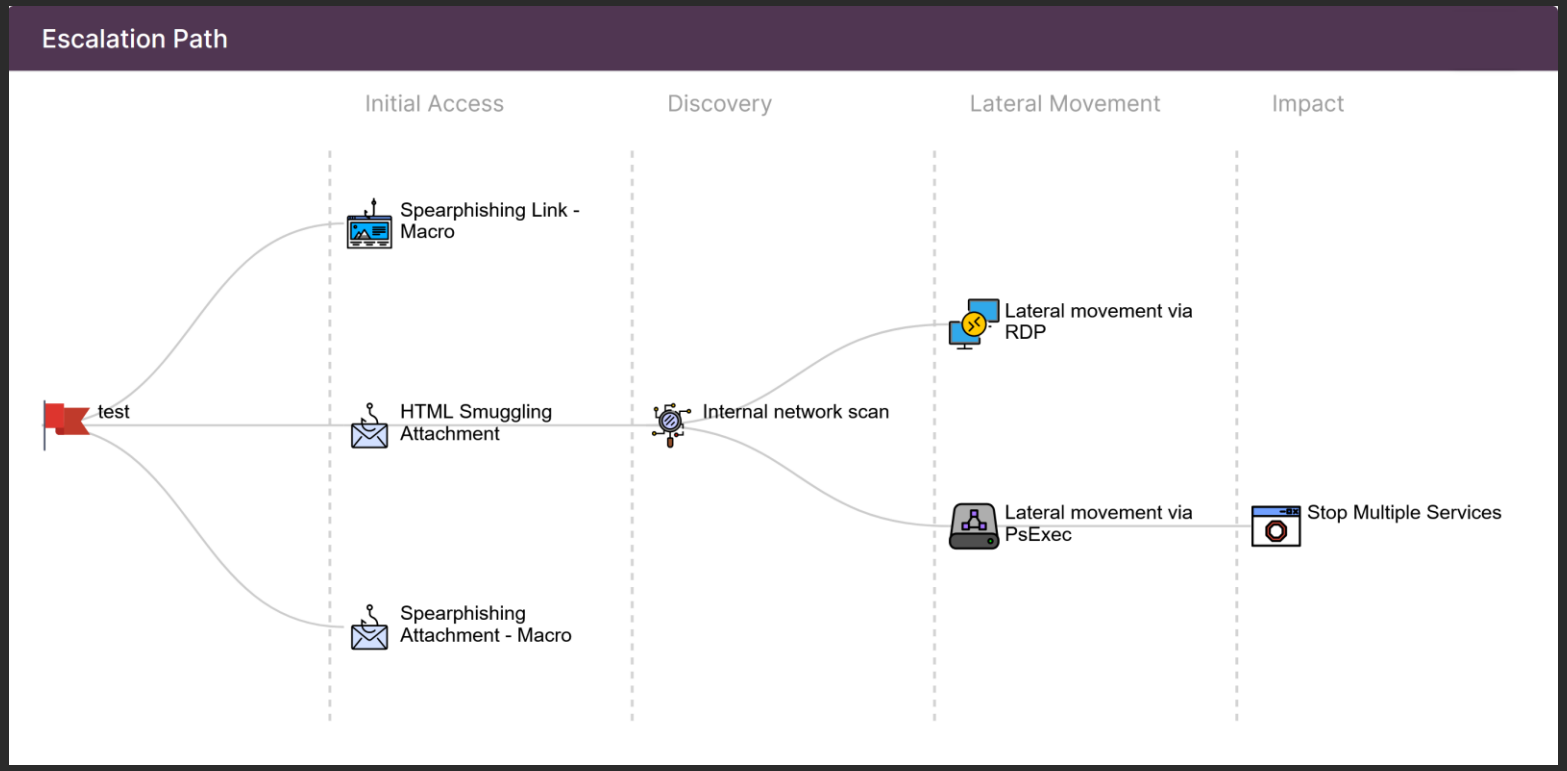
TEST CASES

Spearphish Link	Blocked
Network Scan	Alerted
RDP Lat. Movement	Logged
Modbus Scan	None
Service Stop	Alerted

02 Identifying Techniques

TIPS FOR SUCCESS

- **Verify technique-to-asset mapping:** Older systems (Windows CE) may not support certain tools
- **Use light-touch when possible:** Full TCP connections with sensible delays
- **PCAP replays for network simulation:** Simulate Triton traffic without affecting real devices
- **Lean on robust devices:** Printers can handle aggressive tests without crashing



03 Execution

Performing your test plan

1

Select A Test Case

2

RED Team Executes

3

BLU Team Observes

4

Record Results

5

Repeat

Internal port scan against OT network Test Case

ENTERPRISE

STATUS: InProgress

ATTACK TIMELINE

Attack Start

02/20/2026 16:34:49
status changed to InProgress

Attack Stop

02/20/2026 16:34:50

ASSETS

Sources

- JUMPSRVR01

Targets

- 192.168.1.0/24 (Printer Subnet)

RED TEAM

Name

Internal port scan against OT network

Description

Run internal port scan to probe for interesting OT-specific ports

Technique

T1046 - Network Service I

Phase

Discovery

Operator Guidance

```
shell> nmap -n -v --scan-delay 1 --open -Pn -sT --max-retries 1 -p 20000,44818,1089-1091,102,502,4840,80,443,349 -oA output 192.168.1.0/24
```

Automation

Supported Platform(s): Windows, Linux/MacOS (Bash shell)

Build/Run | Logs

Configure | Build & Download

Execution Artifacts

BLUE TEAM

Detection Time

02/20/2026 16:38:29
outcome changed to Logged

Test Case Outcome

Test Case Outcome

Logged

Defense Success: **Unsuccessful**

Defense Activity

+Tools

Defense Layer:	SIEM
Defense Tool:	Armis (Armis)
Outcome:	Logged
Defense Layer:	ID/PS
Defense Tool:	*No Available ID/PS Tool* (ID/PS)
Defense Layer:	Firewall
Defense Tool:	*No Available Firewall Tool* (Firewall)

Outcome Notes

Network logs are visible in Armis
Custom port scan rule was expected to fire, but may require tuning

Cancel | Save

03 Execution

TIPS FOR SUCCESS

- **Be ready to unlock accounts:** EDRs may isolate hosts and/or accounts after multiple alerts
- **Know your IOAs ahead of time:** Document indicators of attack for each technique so that you know what to look for
- **Beware static signatures:** Don't trust alerts that rely on file hashes, command lines, or other static data
- **Track all artifacts:** Revert any registry modifications, new users, firmware changes, etc.
- **Notify the team:** Or don't! Great opportunity to test your MSSPs real response to an incidents

04 Analyzing Results

A Identify Gaps

Review every failed test and note what was wrong

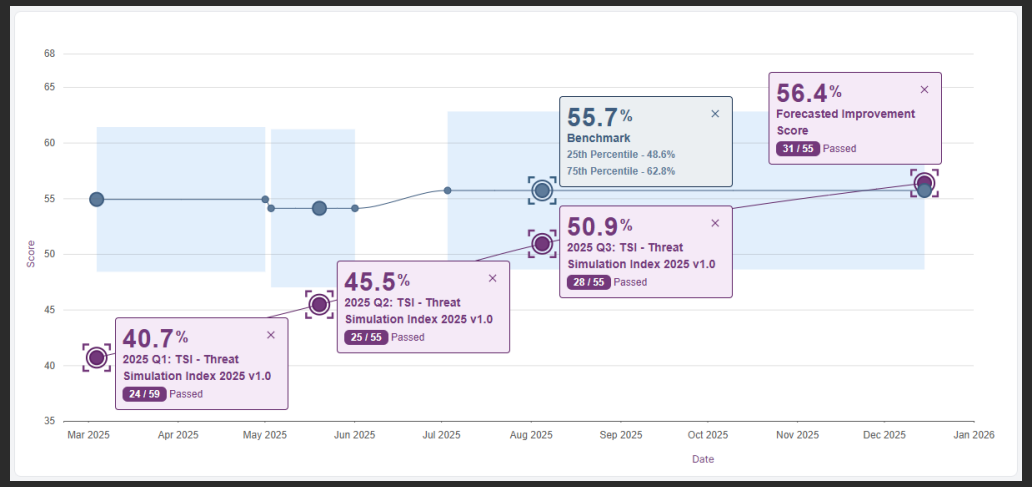
B Remediation Plan

Brainstorm solutions for each defensive gap

Ex: new alert logic, tool config changes, playbook updates

C Test Again!

Re-run your kill chain to verify improvements. Compare results to show measurable growth



Measure & Demonstrate Growth

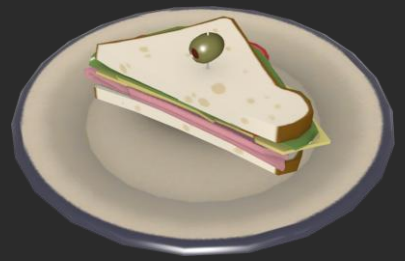
Comparing results across multiple runs is a great way to demonstrate the value of your security program. Create and reach improvement goals based on your test results. Show fewer misses and more blocks with each iteration

Final Take-Aways

And why you're ready for this now

- The project can be as ambitious or as conservative as you want
- Identify what needs improvement
- Demonstrate the value of a tool or control

Thanks,
And have fun!



Connor Jackson
bootskiing.github.io
github.com/BootSkiing
linkedin.com/in/bootskiing

BSides ICS 2026 • Miami